DEFINING AUTHORIZATION POLICIES BASED ON USER ROLES

The Catalog Service endpoints should be protected according to the following policies:

- All `GET` requests sent to the `/`,`/books` or `/books/{isbn}` endpoints should be allowed, even without authentication.
- Any other request should require both user authentication and the `employee` role.

Spring Security provides an expression-based DSL for defining authorization policies. The most generic one is `hasAuthority("ROLE_employee")`, which you can use to check for any type of authority. In our case, authorities are roles, so we can use the most descriptive `hasRole("employee")` and drop the prefix (which is added by Spring Security under the hood).

Listing 12.10 Applying RBAC to limit write access to users with the `employee` role

```
@EnableWebSecurity
public class SecurityConfig {

  @Bean
  SecurityFilterChain filterChain(HttpSecurity http) throws Exception {
    return http
      .authorizeHttpRequests(authorize -> authorize
        .mvcMatchers(HttpMethod.GET, "/", "/books/**")
          .permitAll()                                          ❶
          .anyRequest().hasRole("employee")                     ❷
      )
      .oauth2ResourceServer(OAuth2ResourceServerConfigurer::jwt)
      .sessionManagement(sessionManagement -> sessionManagement
        .sessionCreationPolicy(SessionCreationPolicy.STATELESS))
      .csrf(AbstractHttpConfigurer::disable)
```